

Guía de Auditoría y Control de Datos en MySQL

Para garantizar que el despliegue de permisos es exacto y evaluar de forma eficiente el trabajo en la terminal, no basta con ejecutar las sentencias de control de datos (DCL). Es fundamental auditar el diccionario de datos interno de MySQL.

A continuación, se presenta la guía completa estructurada, incorporando las consultas de verificación directas a las tablas del sistema para comprobar que cada paso se ha ejecutado correctamente.

1 Arquitectura de Cuentas: Usuario y Host

En MySQL, una cuenta se define estrictamente por la combinación de nombre de usuario y el host desde el que se conecta ('usuario'@'host').

1.1 Creación y Modificación

Crear un usuario:

```
CREATE USER 'dev_app'@'10.0.0.%' IDENTIFIED BY 'PasswordSegura123!';
```

Bloquear una cuenta temporalmente:

```
ALTER USER 'dev_app'@'10.0.0.%' ACCOUNT LOCK;
```

Verificación de Cuentas

Para comprobar que el usuario se ha creado con los atributos correctos, consulta la tabla principal del sistema:

```
SELECT host, user, plugin, authentication_string, account_locked  
FROM mysql.user  
WHERE user = 'dev_app';
```

2 Gestión de Privilegios (GRANT / REVOKE)

La asignación debe basarse en el principio de mínimo privilegio. Evita los permisos globales (*.*) y ajusta el acceso a la base de datos o tabla específica.

2.1 Asignación y Revocación

Nivel de Base de Datos:

```
GRANT SELECT, INSERT, UPDATE, DELETE ON tienda_web.* TO 'app_backend'@'localhost';
```

Nivel de Tabla y Columna:

```
GRANT SELECT, UPDATE (precio, stock) ON tienda_web.productos TO 'gestor_precios'@'%';
```

Revocar permisos:

```
REVOKE DELETE ON tienda_web.* FROM 'app_backend'@'localhost';
```

Verificación de Privilegios

Aunque `SHOW GRANTS FOR 'usuario'@'host';` es útil, para automatizar comprobaciones es mejor consultar las tablas de privilegios específicas:

```
-- Verificar privilegios globales (deben estar en 'N' para usuarios normales)
SELECT user, host, Select_priv, Insert_priv, Super_priv
FROM mysql.user WHERE user = 'app_backend';

-- Verificar privilegios a nivel de base de datos
SELECT host, user, db, Select_priv, Insert_priv
FROM mysql.db WHERE user = 'app_backend';

-- Verificar privilegios a nivel de tabla
SELECT host, user, db, table_name, table_priv, column_priv
FROM mysql.tables_priv WHERE user = 'gestor_precios';
```

3 Implementación de Roles (MySQL 8.0+)

Los roles agrupan permisos y estandarizan la seguridad, evitando la gestión individualizada que propicia errores humanos.

3.1 Flujo de Trabajo con Roles

Crear y configurar el rol:

```
CREATE ROLE 'rol_lectura';
GRANT SELECT ON erp_empresa.* TO 'rol_lectura';
```

Asignar y activar el rol en el usuario:

```
GRANT 'rol_lectura' TO 'empleado_ventas'@'%';
SET DEFAULT ROLE ALL TO 'empleado_ventas'@'%';
```

Verificación de Roles

Para comprobar qué roles están asignados y si están configurados para activarse por defecto:

```
-- Ver las relaciones entre roles y usuarios
SELECT from_user AS 'Rol', to_user AS 'Usuario_Asignado'
FROM mysql.role_edges
WHERE to_user = 'empleado_ventas';

-- Ver si el rol se activa automaticamente al inicio de sesion
SELECT user, default_role_user AS 'Rol_Por_Defecto'
FROM mysql.default_roles
WHERE user = 'empleado_ventas';
```

4 Ejercicios Prácticos y Solucionario

Escenario: Trabajas desde la terminal MySQL como root. Existe una base de datos llamada `sistema_academico`.

Ejercicio 1: Despliegue seguro de aplicación

- Crea el usuario `webapp_front` limitado a la IP `192.168.50.100`.
- Otórgale solo permisos de lectura (`SELECT`) sobre `sistema_academico`.
- **Comprobación:** Escribe las consultas para verificar la creación del usuario y sus permisos a nivel de base de datos.

Solución Ejercicio 1:

```
CREATE DATABASE IF NOT EXISTS sistema_academico;
CREATE USER 'webapp_front'@'192.168.50.100' IDENTIFIED BY 'PasswordFuerte123!';
GRANT SELECT ON sistema_academico.* TO 'webapp_front'@'192.168.50.100';

-- Consultas de verificacion
SELECT host, user FROM mysql.user WHERE user = 'webapp_front';
SELECT host, user, db, Select_priv, Insert_priv FROM mysql.db WHERE user = '
webapp_front';
```

Ejercicio 2: Diseño basado en Roles (RBAC)

- Crea los roles `auditor_academico` (solo `SELECT`) y `gestor_matriculas` (`INSERT`, `UPDATE`).
- Crea el usuario local `secretaria_juan` y asígnale ambos roles, activándolos por defecto.
- **Comprobación:** Verifica en el diccionario de datos que los roles se han vinculado correctamente al usuario.

Solución Ejercicio 2:

```
CREATE ROLE 'auditor_academico', 'gestor_matriculas';
GRANT SELECT ON sistema_academico.* TO 'auditor_academico';
GRANT INSERT, UPDATE ON sistema_academico.* TO 'gestor_matriculas';

CREATE USER 'secretaria_juan'@'localhost' IDENTIFIED BY 'PassSecre456!';
GRANT 'auditor_academico', 'gestor_matriculas' TO 'secretaria_juan'@'localhost';
SET DEFAULT ROLE ALL TO 'secretaria_juan'@'localhost';

-- Consultas de verificacion
SELECT from_user, to_user FROM mysql.role_edges WHERE to_user = 'secretaria_juan';
SELECT user, default_role_user FROM mysql.default_roles WHERE user = '
secretaria_juan';
```

Ejercicio 3: Auditoría y corrección de incidentes

- **Simula este error crítico:** `CREATE USER 'dev_junior'@'%' IDENTIFIED BY '1234'; GRANT ALL PRIVILEGES ON *.* TO 'dev_junior'@'%'`;
- **Corrige el problema:** revoca los privilegios globales, asígnale solo DML (SELECT, INSERT, UPDATE, DELETE) confinado a `sistema_academico` y fuerza la expiración de su contraseña.
- **Comprobación:** Demuestra mediante una consulta a `mysql.user` que el usuario ya no tiene privilegios globales.

Solución Ejercicio 3:

```
-- 1. Simulacion del error
CREATE USER 'dev_junior'@'%' IDENTIFIED BY '1234';
GRANT ALL PRIVILEGES ON *.* TO 'dev_junior'@'%'

-- 2. Correccion
REVOKE ALL PRIVILEGES, GRANT OPTION FROM 'dev_junior'@'%'
GRANT SELECT, INSERT, UPDATE, DELETE ON sistema_academico.* TO 'dev_junior'@'%'
ALTER USER 'dev_junior'@'%' PASSWORD EXPIRE;

-- 3. Consultas de verificacion (Auditoria rigurosa)
-- Comprobamos que a nivel global ya no tiene poder
SELECT user, host, Select_priv, Drop_priv, Super_priv
FROM mysql.user WHERE user = 'dev_junior';

-- Comprobamos que la contraseña esta marcada como expirada
SELECT user, host, password_expired
FROM mysql.user WHERE user = 'dev_junior';

-- Comprobamos que sus permisos estan confinados a la BD correcta
SELECT host, user, db, Select_priv, Delete_priv, Drop_priv
FROM mysql.db WHERE user = 'dev_junior';
```